Unidad 8 - Seguridad en Redes

Toda organización **debe** definir CUÁL es el concepto de seguridad para ella, es decir: ¿Qué se debe cuidar?

Por ejemplo:

- Una red es segura si nadie ajeno puede acceder a sus computadoras.
- Una red es segura cuando se permite el acceso a los datos, pero se prohíbe cambiarlos.
- Una red es segura cuando se permiten accesos a los datos públicos y no a los datos privados.

La seguridad en redes busca minimizar la **vulnerabilidad** de los sistemas o de la información contenida en ellos.

Vulnerabilidad: es alguna característica del sistema informático que puede ser usado por una amenaza.

Amenaza: es un evento no deseado, el cual puede perjudicar a la organización.

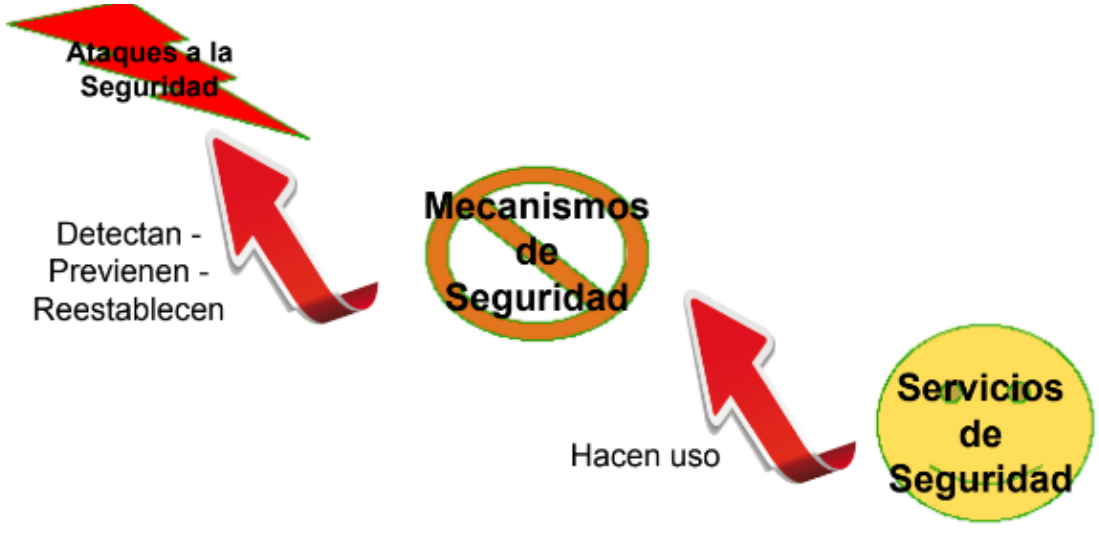
Ejemplos de vulnerabilidades:

- Uso de SO no actualizados
- Comunicaciones sin cifrar
- Falta de antivirus
- No existe control de accesos al sistema
- No tener el control de software que se descarga de internet
- Ex empleados que conserven acceso a los recursos.

¿Qué es una política de Seguridad?

Conjunto de reglas y prácticas a aplicar en una organización con el objetivo de dirigir, proteger y distribuir sus recursos para cumplir con los objetivos de seguridad informática definidos previamente.

Arquitectura de Seguridad



Tipos de Ataques a la Seguridad

- **Pasivos:** no afectan a los recursos del sistema, estos se deben **prevenir**.
    - **Obtención del contenido mensaje:** el vulnerador extrae un mensaje de la red y lee su contenido (Ejemplos: espiar información, obtención de archivos, escucha de conversaciones, obtención de correos, etc.).



    - **Análisis del tráfico:** observa patrones (hora, frecuencia de envío, etc.) en el envío de mensajes (Ejemplos: determinar la localización e identidad de los servidores, descubrir frecuencia y longitud de los mensajes que se intercambian.)



- **Activos:** buscan alterar el funcionamiento o los recursos del sistema, estos se deben **detectar** y **recuperar**.
    - **Suplantación de identidad:** ocurre cuando un atacante (en el ejemplo, Salomón) se hace pasar por una entidad legítima (como Carlos) para engañar a un receptor (el jefe) y obtener accesos, información confidencial o realizar acciones maliciosas en su nombre.



      Ejemplos:
        - *Phishing*: busca engañar a la víctima haciéndose pasar por una persona o entidad confiable para que revele información sensible o confidencial como contraseñas, números de tarjetas de crédito, etc.
        - *IP spoofing:* el atacante manipula los paquetes de red para que parezcan provenir de una dirección IP falsa o de confianza, para ocultar la verdadera identidad del atacante o para suplantar la identidad de otra máquina en la red. Con esto puede lograr engañar al sistema de red y evadir filtros.

- **Repetición:** se intercepta un mensaje, y se reenvía provocando efectos maliciosos o no autorizados. El atacante puede hacer que el sistema procese el mensaje nuevamente como si fuera legítimo.



- **Modificación del Mensaje:** aquí no hay repetición sino que se intercepta el mensaje y el original nunca llega al destino.



- **Interrupción de Servicio:** se interrumpen servicios proporcionados por servidores. Ejemplos: ataque DoS (Denial of Service), DDoS (Distributed Denial of Service), malware (software malintencionado), etc.







Aspectos Principales de los Servicios de Seguridad

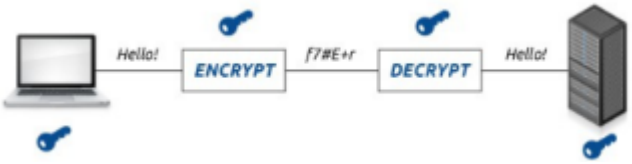
a) **Confidencialidad**: Supone proteger la información sensible, la información privada debe mantenerse privada. Solo las personas o sistemas autorizados pueden tener acceso a ella, esto implica prevenir accesos no autorizados y proteger la privacidad de los datos.
b) **Disponibilidad**: Que los datos, servicios o sistemas estén disponibles cuando el usuario los necesite. Implica proteger contra sistemas de interrupción de servicio o problemas técnicos.
c) **Integridad**: Que la información sea precisa y no sea alterada o manipulada sin autorización asegurando que los datos estén completos y sean confiables. Y que los mensajes enviados lleguen a destino sin alteraciones.

Otros aspectos a tener en cuenta:

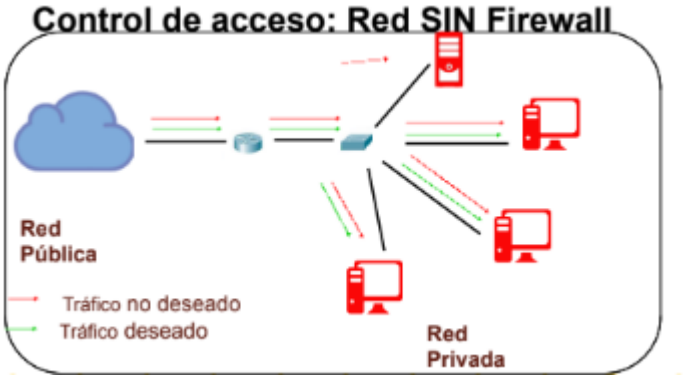
- **Autenticación**: controla que la entidad que se comunica es quien dice ser (credenciales, usuario y contraseña, etc.).
- **No Repudio:** prueba que el mensaje fue enviado o recibido por alguna entidad de la comunicación. La entidad no puede negar haber realizado la acción.

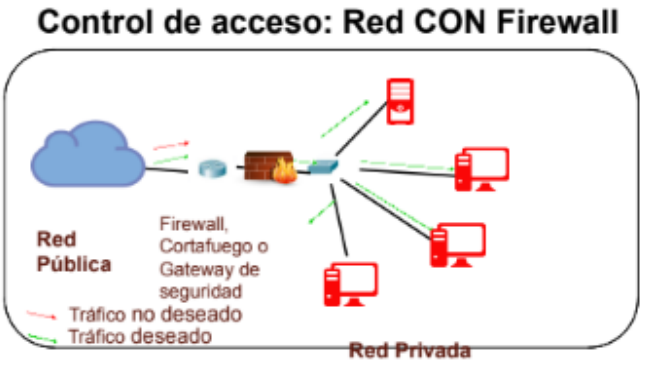
Mecanismos de Seguridad

- **Cifrado o encriptación:** método mediante el cual el texto legible(plano) se convierte en texto ilegible (cifrado) mediante una traducción reversible(algoritmo de cifrado), esto para proteger la información de accesos no autorizados.



  - Asimétrico: se usa una clave de cifrado (algoritmo) para cifrar y otra para descifrar los datos.
  - Simétrico: se usa la misma clave de cifrado (algoritmo) para cifrar y otra para descifrar los datos.
  - Híbrido: combina los dos métodos anteriores.
- **Integridad de Datos**
  - Función de Hash
  - Firma Digital
- **Control de Acceso**: mecanismos que controlan quién puede y quién no puede acceder a los recursos de la red, archivos, etc. para proteger la información de accesos no autorizados.
  - **Firewall:** dispositivo o software que se configura para monitorear y controlar el tráfico entrante y saliente de una red basado en un conjunto de reglas predefinidas y criterios de seguridad. Actúa como barrera contra accesos no autorizados.





Características

- Todo el tráfico DEBE pasar por el firewall.
- Se permite SÓLO el tráfico autorizado.

- El firewall debe ser INMUNE a los ataques.
- El objetivo es CONTROLAR la información a acceder

Funciones

- Permitir o denegar los accesos desde la red local hacia el exterior y viceversa.
- Filtrar los paquetes.
- Monitorizar el tráfico.
- Almacenar total o parcialmente los paquetes que circulan a través de él para analizarlos en caso de problemas.

Ventajas	Desventajas
Protege de Intrusiones	No puede proteger ataques que no pasen por él
Protección de información privada	No puede protegerse de las amenazas a que está sometido por traidores o usuarios inconscientes.
Disminuye el tráfico indeseado	No puede protegerse contra los ataques posibles a la red interna por virus informáticos a través de archivos y software.
Centraliza los accesos	No protege de los fallos de seguridad de los servicios y protocolos de los cuales se permita el tráfico.
Genera alarmas de seguridad	
Monitorea y registra el uso de internet	

Actúa de dos formas:

- **Aceptar Todo:** acepta todos los mensajes, analiza uno por uno y si son mensajes confiables los deja pasar, de lo contrario, los rechaza.
- **Denegar Todo:** deniega todos los mensajes. Solo aquellos mensajes que están explícitamente permitidos pasan.

    - **Proxy**: dispositivo que actúa como intermediario entre la red privada (interna) y la red pública (internet). También se lo puede ver como un intermediario entre el programa cliente y el servidor.



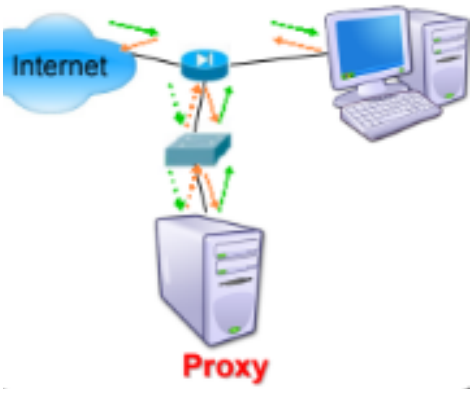


Su objetivo es evitar la comunicación directa entre la computadora que solicita el servicio con el servidor real.



Funciones

- Mantener a las máquinas en el anonimato
- Aplicar políticas de acceso a servicios
- Auditar el uso de internet
- Escaneo del contenido en busca de malware antes de reenviarlo
- Mejorar el tiempo de respuesta y ahorro de tráfico



Caché del Proxy

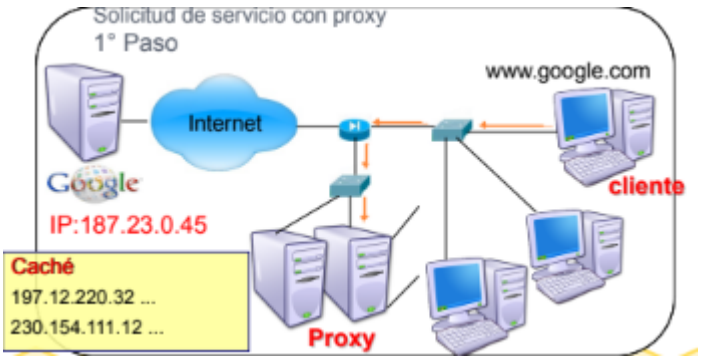
Almacena en caché una copia de los pedidos frecuentemente solicitados, mejorando la velocidad de acceso a recursos comunes y reduciendo el consumo de ancho de banda.

Características

- Es una memoria pequeña y rápida
- Almacena también los últimos ingresos y va descartando los más antiguos.
- Cuando una computadora hace una solicitud a una dirección que ya fue ingresada anteriormente, el proxy devuelve directamente el contenido de la dirección en lugar de volver a buscarlo en el servidor.

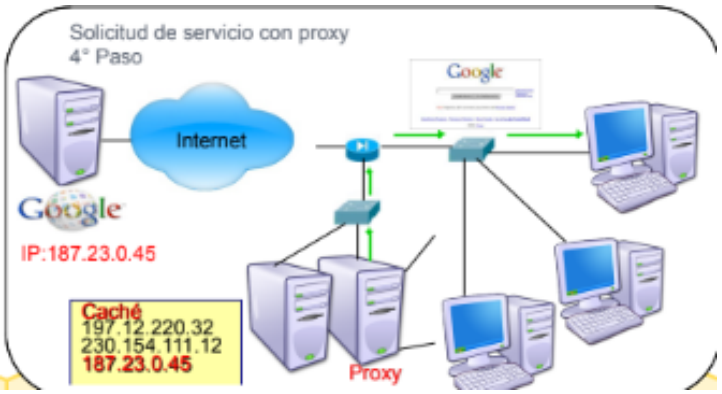
Pasos del Proceso (Luego agregar explicación de cada uno)

Caso de Primera Solicitud a esa Dirección

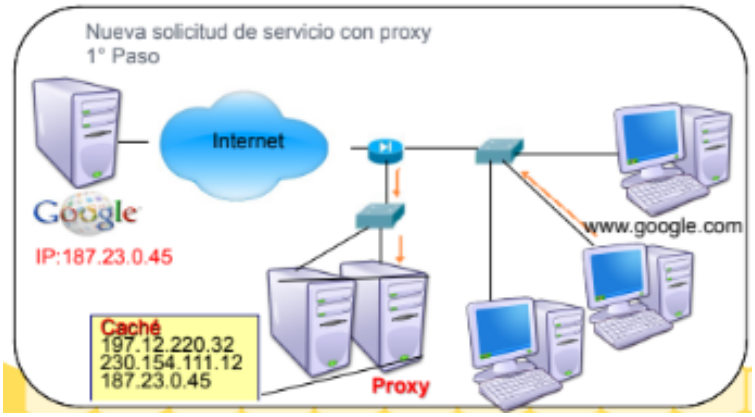








Caso de que No es la Primera Solicitud a esa Dirección





Ventajas	**Desventajas**
Ahorro de tráfico	Intromisión: se puede no querer guardar copias de los datos.
Velocidad en tiempo de respuesta	Incoherencia de caché: es posible que el proxy dé una respuesta equivocada.
Filtrado de contenidos	Sobrecarga
Anonimato	

Implementación de los servicios a través de los diversos mecanismos

Aspecto	Mecanismo
Confidencialidad	**Encriptación**: Cifra los datos para que solo los usuarios autorizados puedan acceder a la información. **Control de Acceso**: firewall / proxy
Integridad	**Encriptación**: al no dejar que usuarios no autorizados modifiquen datos. **Control de Acceso**: al controlar quién tiene acceso a los datos y permisos para modificarlos. Esto lo puede hacer mediante un ***Proxy***, que restringe el acceso a ciertos sitios o servicios, o mediante un ***Firewall***, que define reglas que aseguran que solo los usuarios autorizados puedan usar la red o comunicarse en ella.
Autenticación	**Acceso encriptado**: se usan https o protocolos seguros. **Acceso remoto**: ssh o protocolos de acceso remoto encriptado o que requieran credenciales para acceder.
Disponibilidad	**Redundancia**: que los datos estén disponibles en más de un lugar y no centralizados. **Backup**: contar con copias de seguridad para poder restaurar la información en caso de fallos.